

ATTACHMENT SCY
Security Requirements

1. DEFINITIONS

- (a) **“Agreement”** means the Agreement between the Contractor and the City, annexed hereto.
- (b) **“Authorized Person”** has the meaning given below in Section 16(a).
- (c) **“Authorized Subcontractor”** has the meaning given below in Section 16(a).
- (d) **“City”** means the City of New York and/or a county, borough, or other office, position, administration, department, division, bureau, board or commission, or a corporation, institution or agency of government, including Cyber Command, the expenses of which are paid in whole or in part from the City of New York’s treasury, or an entity created under New York law specifically for the benefit of the City or to serve persons present in the City of New York and that has 1 or more members or directors of which are appointed by the mayor or City Council (e.g., the New York City Board of Elections).
- (e) **“City Data”** means (1) Data characterizing the City or its behavior; (2) Data created, generated, stored or maintained by, at the direction of, or for the benefit of the City; and (3) any copies or derivatives of such Data. **“Data”** means any information representation(s) of information, knowledge, facts, ideas, concepts or similar including any texts, instructions, documents, databases, diagrams, graphics, drawings, images, sounds, or biometrics that are accessed, communicated, created, generated, stored (in temporary or permanent form), filed, produced or reproduced, processed, referenced, or transmitted, in any form or media.
- (f) **“City Technology Assets”** means all City Facilities, City Systems, City telecommunications, electronic data created, processed, accessed, transferred, stored, or disposed of by City Systems, and such systems’ peripheral equipment, networks, or magnetic data, and any electronic data created, processed, accessed, transferred, stored, or disposed of by such systems. **“City Systems”** means any system owned, maintained or operated by or on behalf of the City that connects to a City network, enables operational functions of the City, or creates, processes, accesses, transfers, stores, or disposes of City Data.
- (g) **“Commissioner”** or **“Agency Head”** means the head of a City entity.
- (h) **“Contractor”** means a person or entity engaged by the City of New York to perform tasks pursuant to the Agreement.
- (i) **“Cyber Command”** means the Office of Cyber Command, established within the New York City Office of Technology and Innovation (**“OTI”**), that is empowered to ensure compliance with Policies and Standards, mitigate cyber threats, mandate deployment of technical and administrative controls, review cyber related spending, and collaborate with federal and

state government agencies and private sector organizations.

- (j) **“DoITT”** means the Department of Information Technology and Telecommunications.
- (k) **“Facility(ies)”** means a physical structure, such as a data center or other building.
- (l) **“Person”** means an officer, agent or employee of the Contractor or a subcontractor of the Contractor.
- (m) **“Policies and Standards”** means the Citywide Information Security Policies and Standards, Cyber Command Policies and Standards, or any policies and procedures by OTI, available at <https://www1.nyc.gov/content/oti/pages/vendor-resources/cybersecurity-requirements-for-vendors-contractors>, as they may be amended or placed on a successor site by the City.
- (n) **“Process”** means to perform any act, omission or operation on or with respect to data, such as collecting, recording, organizing, storing, adapting, altering, retrieving, accessing, deleting, blocking, erasing, destroying, combining, reviewing, using, transmitting, disseminating or otherwise making data available.
- (o) **“Project”** means any type of work to be performed pursuant to the Agreement.
- (p) **“Contractor Systems”** means the Facilities, systems, networks and IT environments that are used to Process any City Data, deliver any services or to otherwise meet any of Contractor’s obligations under the Agreement.
- (q) **“Security Incident”** means an event that compromises the security, confidentiality, availability or integrity of City Data, City Technology Assets or Contractor Systems, including by compromising the physical, technical, administrative or organizational safeguards implemented by Contractor to protect the security, confidentiality, availability or integrity of City Data, City Technology Assets or Contractor Systems. Examples of a Security Incident include, but are not limited to, the unauthorized acquisition or use of unencrypted City Data (or encrypted City Data and the decryption key), intrusions, virus or malware, ransomware infections, social engineering, missing/stolen hardware, a breach of access credentials, DDOS and DoS attacks
- (r) **“Security Investigation”** means a criminal history and background investigation in accordance with the requirements set forth herein. The City reserves the right to modify the scope of requisite investigations upon provision of reasonable notice to the Contractor.
- (s) **“User Responsibility Policy”** or **“URP”** means the User Responsibilities Policy available at <https://www1.nyc.gov/assets/oti/downloads/pdf/vendor-resources/user-responsibilities.pdf>, as it may be amended or placed on a successor site by the City.

2. CITYWIDE INFORMATION SECURITY POLICY

The Contractor shall comply with the Policies and Standards, and terms of the Agreement. In addition, the Contractor shall ensure that all Authorized Subcontractors and Authorized Persons who may have access to any City Data or City Technology Assets in the course of carrying out their responsibilities or job functions comply with the Policies and Standards.

3. USER RESPONSIBILITY POLICY

The Contractor will be provided with online access to, or a copy of, the User Responsibility Policy. The Contractor shall require each Authorized Person (as defined below in Section 16(a)) who may have access to any City Technology Assets to sign a written acknowledgement and agreement to comply with its terms prior to his or her assignment to perform any Services. The Contractor shall provide a signed copy of the URP acknowledgement for each Authorized Person to the City project manager, or a person designated by the City, within fifteen days (15) days after the Authorized Person is assigned to perform Services.

4. SECURITY INVESTIGATION

- (a) The City may, prior to or during the course of the Agreement, request that the Contractor require a Person, or Persons, associated with the Services to undergo a Security Investigation before being granted access, or continued access, to Facilities, City Data, City Technology Assets or Contractor Systems. The City may require the Contractor and associated Persons to undergo federal, state and local background checks, where authorized by applicable law, that conform to industry standards, including criminal history and/or background investigation. Persons assigned to the Project by or through the Contractor shall be required to submit Identifying Information to the City, and may, to the extent authorized by applicable law, be required to submit fingerprints. The Contractor and associated Persons agree to be subject to a background screening and checks, which may include the following:
 - (i) Employment Verification;
 - (ii) Education Verification;
 - (iii) Reference Verification;
 - (iv) Criminal Record Check;
 - (v) Civil Court Records Check;
 - (vi) Professional License Check;
 - (vii) Credit History Check;
 - (viii) International Background Check; and
 - (ix) Terrorist Watch List Check.
- (b) If Security Investigations are requested or required by the City prior to the commencement of work by the Person, the Contractor is required to submit the results of the Security Investigation for each Person that it proposes to assign to perform services sufficiently in advance to ensure that all security clearance procedures are complete without delaying the Contractor's work performance. The City shall not be liable for payments or damages of any kind if the Contractor's work is delayed or the Contractor is required to assign different individuals on account of the City's reasonable delay or refusal

to grant an individual a security clearance under the Agreement.

- (c) The Contractor shall assume, without any reimbursement by the City, all costs incurred in connection with the investigations.
- (d) Where an emergency or other circumstance occurs which renders immediate compliance impractical, the City may, in its sole judgment, defer a Person's compliance and grant temporary access, pending the results of the Security Investigation. Such deferment shall not be construed as a waiver of the City's right subsequently to require that a Security Investigation be performed.
- (e) The City reserves the right, in its sole discretion, to refuse access to City Data or City Technology Assets: **(i)** to any individual who refuses to comply with the security or non-disclosure procedures required by Cyber Command or **(ii)** where the Cyber Command determines that the individual may present a risk to its security interests.

5. COMPLIANCE WITH OTHER SECURITY POLICIES AND PROCEDURES

In addition to the Policies and Standards and the User Responsibility Policy, the Contractor shall comply with, and ensure that all Authorized Subcontractors and Authorized Persons comply with, all applicable Facility, data processing and other security policies and procedures of the Cyber Command in effect for the duration of the Agreement, including, but not limited to, processing, handling and storage of Restricted and Sensitive Information, Internet usage, office equipment usage and timekeeping procedures. This may include being required to sign in and out and enter time worked into a timekeeping system provided by the City.

6. NOTIFICATION OF TERMINATION, REASSIGNMENT OR CESSATION OF ACCESS

The Contractor shall promptly notify Cyber Command and the City liaison assigned to the Services, in writing, when any Person previously engaged by the Contractor to gain access to any Facilities, City Data, City Technology Assets or Contractor Systems is no longer authorized by the Contractor to do so, and the Contractor shall make reasonable efforts to prevent any such Person from accessing any Facilities, City Data or City Technology Assets from the point in time that such individual's authorization ceases.

7. NON-DISCLOSURE AGREEMENT

If reasonably requested by the City, the Contractor shall require its Authorized Subcontractors and Authorized Persons who either work in direct support of the Services or who may reasonably be anticipated to unintentionally receive City Data to execute a Non-Disclosure Agreement in a form acceptable to the City.

8. CONTRACTOR-PROVIDED EQUIPMENT

The Contractor shall ensure that any products, services and other deliverables it provides to the City are compliant with the Policies and Standards.

9. NO INTRODUCTION OF VIRUSES

The Contractor shall use industry standards to ensure that it does not introduce any viruses or any other form of malicious code to City systems.

10. COOPERATION WITH ACCREDITATION

The Contractor shall cooperate with and facilitate the successful completion of any security accreditation tasks and processes relevant to the services and/or deliverables it provides. The Contractor shall complete said security accreditation tasks and processes within thirty (30) business days unless granted an extension by Cyber Command.

11. VENDOR SECURITY QUESTIONNAIRE

The Contractor shall complete and respond to all security questionnaires from the City within thirty (30) business days.

12. CONTRACTOR'S POLICIES

Upon request, the Contractor shall provide a copy of its information security policies relevant to the Agreement.

13. CITY AUDIT(S)

The City reserves the right to audit the IT infrastructure and information security controls and processes of the Contractor and to perform relevant tests to ensure that it is compliant with the Policies and Standards at any time. The Contractor will permit the City to perform an IT audit, including an audit of physical security of any of the Contractor's premises applicable to the services provided pursuant to the Agreement and will cooperate and furnish all requested materials in a timely manner. Cyber Command reserves the right to monitor the security posture of the Contractor throughout the course of the Agreement.

14. SOFTWARE SECURITY ASSURANCE (SSA) APPROVAL

The Contractor agrees to submit all devices, applications, systems, software and infrastructure used to support City systems, pursuant to the Agreement, to security testing in compliance with the City's Software Security Assurance process. The Contractor understands and acknowledges that failure to meet the SSA process requirements can result in termination of the Agreement.

15. REQUIREMENTS FOR SYSTEMS PROVIDING CRITICAL FUNCTIONS

- (a) If Contractor maintains systems that provide critical City capabilities and/or functions, Contractor shall provide the City with reports verifying that all patches and configurations are up to date, as well as forecast all required changes for the next twelve (12) months.
- (b) The Contractor shall ensure that all necessary capabilities and equipment potentially required to service critical technology in the event of an incident is locally available.

16. USE AND PROTECTION OF CITY DATA/INDEPENDENT REVIEW(S)/AUDIT(S)

- (a) The Contractor shall hold City Data in the strictest confidence, and shall not disclose any City Data to any person or entity other than a subcontractor that has been approved by the City in writing (each, an “**Authorized Subcontractor**”) or an employee of the Contractor or an Authorized Subcontractor who needs to know the City Data in order to perform the Contractor’s obligations under the Agreement (each, an “**Authorized Person**”).
- (b) The Contractor shall ensure that each Authorized Subcontractor is subject to an enforceable written obligation to comply with the terms and conditions in this Attachment SCY. Within ten (10) days of the City’s request, the Contractor shall provide the City with a copy of its contract with any Authorized Subcontractor.
- (c) The Contractor shall be liable for the full or partial breach of any of the terms of this Attachment SCY by: **(A)** any of its subcontractors, whether or not an Authorized Subcontractor, or **(B)** any Person, whether or not an Authorized Person.
- (d) The Contractor shall protect the privacy and security of City Data in accordance with the Agreement, industry best practices and all applicable laws, regulations and standards, including the Policies and Standards. Contractor shall implement, maintain and use appropriate administrative, technical and physical controls to ensure the security, confidentiality, integrity, and availability of City Data, including, without limitation, to prevent the unauthorized, unlawful, or accidental use, destruction, alteration, disclosure, access, modification, or loss of City Data.
- (e) The Contractor shall engage a third-party internationally recognized auditor to perform periodic audits, scans, and tests as follows:
 - (i) At least once per year and after any Security Incident that occurs during the Term:
 - (1) a SSAE 18/SSAE 16/SOC-1, Type II audit and a SOC-2, Type II audit of Contractor’s controls and practices relevant to security, availability, Processing integrity, confidentiality and privacy of City Data;
 - (2) an audit pursuant to Contractor’s information security program and practices;
 - (3) a network-level vulnerability assessment of all Contractor Systems used to deliver Services under the Agreement or to Process City Data; and
 - (4) a formal penetration test of all Contractor Systems used to deliver services under the Agreement or to Process Contract Data.
 - (ii) The Contractor shall provide Cyber Command with a copy of all unredacted reports generated for each audit, scan, and test within 10 days after its completion. Each report must: **(A)** indicate whether any material vulnerabilities, weaknesses, gaps, deficiencies, or breaches were discovered; and **(B)** if so, describe the nature of each vulnerability, weakness, gap, deficiency, or breach. The Contractor shall, at its own cost and expense, promptly remediate each vulnerability, weakness, gap, deficiency, or breach that is identified in a report.

- (f) The Contractor shall provide Cyber Command with copies of reports from any cybersecurity audit performed, within twelve (12) months of execution of the Agreement, by the Contractor or by a third-party auditor and any cybersecurity audit performed after execution of the Agreement within ten (10) days after the audit's completion.

17. NONCOMPLIANCE SELF REPORTING REQUIREMENT

The Contractor shall notify Cyber Command of any changes to the infrastructure of all information systems that would affect City Data or result in noncompliance with any federal or state law, Policies and Standards, or terms of the Agreement. Notification of each change shall be made to Cyber Command no later than thirty (30) business days after the change has occurred. For noncompliance, the Contractor shall submit to Cyber Command a document that includes the following:

- (i) Date of discovery;
- (ii) How the noncompliance was identified;
- (iii) Nature of the noncompliance;
- (iv) Scope of noncompliance; and
- (v) Corrective actions with associated timelines.

18. VULNERABILITY REPORTING AND NOTIFICATION REQUIREMENT

The Contractor shall inform Cyber Command of any identified vulnerabilities in information systems no later than ten (10) businesses days after receiving notification. The Contractor shall provide a report to Cyber Command that includes a detailed description of the identified vulnerabilities and a remedial plan with associated timelines informing the City and Cyber Command of all actions the Contractor has taken or plans to take to rectify the vulnerabilities.

19. SUGGESTIONS

The Contractor may surface issues, suggest options, and make recommendations to the City with regard to the Policies and Standards where appropriate.

20. LIAISON

At the beginning of the term of the Agreement, the Contractor shall identify and provide contact information for the Person who has been assigned overall responsibility for information security within its organization.

21. NO EXPORTING OF CITY DATA OUTSIDE UNITED STATES

The Contractor may not export City Data outside the United States except with the express written permission of the Commissioner or Agency Head of the City entity, or their designee, to which the City Data belongs, and then only for the City Data specified in that permission.

22. INTEGRITY OF PUBLIC CITY DATA

The Contractor must use industry best practices to ensure that the value and state of all public City Data is maintained and that the public City Data is protected from unauthorized modification.

23. REMOTE ACCESS METHODS

The Contractor must obtain written permission from the City for each method of remote access it wishes to use to access City Technology Assets.

24. WHAT TO DO IN CASE OF A SECURITY INCIDENT

- (a) Contractor shall implement, maintain, test and update a Security Incident response plan. In the event of an actual or suspected Security Incident, Contractor shall:
 - (i) notify the NYC Cyber Command Citywide Security Operations Center ("**Cyber Command Citywide SOC**") by telephone at (718) 403-6761 within 24 hours.
 - (ii) notify the Cyber Command Citywide SOC within 48 hours by written notice to SOC@cyber.nyc.gov, summarizing, in reasonable detail, the nature and scope of the Security Incident (including a description of all impacted City Data and City Technology Assets) and the corrective action already taken or planned by Contractor, which shall be timely supplemented to the level of detail reasonably requested by the City, inclusive of relevant investigation or forensic reports.
 - (iii) promptly, at its own cost and expense, take all reasonable and necessary actions to confirm, contain and end the Security Incident, mitigate its impact to the City, and prevent recurrence.
 - (iv) not delete any impacted virtual/cloud instances or re-image any impacted systems without prior consultation and agreement with Cyber Command.
 - (v) cooperate with the City in the investigation of the Security Incident, including promptly responding to the City's reasonable inquiries and providing prompt access to all evidentiary artifacts associated with or relevant to the Security Incident, such as relevant records, logs, files, data reporting, and other materials.
 - (vi) permit the City, in its sole discretion, to immediately suspend or terminate Contractor's right to create, process, access, transfer, store, or dispose of City Data or operate City Technology Assets.
 - (vii) not inform any third party that the Security Incident involves City Technology Assets or Data without first obtaining the City's prior written consent, except to the extent required by law or by third parties engaged by the Contractor to remediate the Security Incident.
 - (viii) collaborate with the City in determining whether to provide notice of the Security Incident to any person, governmental entity, the media, or other party, and the content of any such notice. The City will make the final determination as to whether notice will be provided and to whom, the content of the notice, and which Party will be the signatory to the notice.

- (ix) bear the responsibility and all related costs for any Security Incident to the extent that the City is not at fault or caused by a vulnerability in the Contractor's product(s) or system(s), including the cost of any associated remedial actions or mitigation steps, consumer notification and related responses, credit monitoring, notification, regulatory investigations, fines, penalties, enforcement actions and settlements.
- (x) promptly notify the City of any investigations of its data use, privacy or cybersecurity practices, or a Security Incident by a governmental, regulatory or self-regulatory body.

25. NOTIFICATION TO CYBER COMMAND

With the exception of the notification requirements applicable to a Security Incident as reflected in Section 24 of this Attachment, Contractor shall submit all notices, including any reporting documents, audit materials and other security documentation, to Cyber Command by email at compliance@cyber.nyc.gov.

26. MATERIAL BREACH

Violations of any part of this Attachment or any of the Policies and Standards shall constitute a material breach of the Agreement.

27. HEADINGS

Headings are inserted only as a matter of convenience and for reference and in no way define, limit, augment or describe the scope or intent of this Attachment.

[END OF ATTACHMENT SCY]